Application launch evidence: access, integrity, agent scope and recovery

Strengths and best use

A launch review becomes actionable when every claim has a fixture, expected result, observed result, and recovery plan. The combined sources cover protected data, application integrity, agent permissions, operational resilience, and usable delivery. The new ten-check reel supplies concrete entry points for that broader evidence workbook. OWASP ASVS (https://owasp.org/www-project-application-security-verification-standard/)

Check identity and data boundaries

Create two synthetic users, a restricted role, and an unauthenticated caller. Exercise protected reads, writes, exports, storage, and bulk endpoints with objects owned by different users. Check server-side authorization, effective database grants, and policies for exposed tables. Hiding a control in the browser does not enforce permission.

For Supabase, distinguish publishable client keys from privileged secrets. Privileged keys stay on trusted server paths. Verify RLS and applicable policies for the actual exposed schema and role. An enabled policy mechanism does not prove that a policy allows only the intended access. API keys (https://supabase.com/docs/guides/api/api-keys) - Row-level security (https://supabase.com/docs/guides/database/postgres/row-level-security)

Protect integrity and spending

Test repeated submissions, concurrent updates, invalid state transitions, and payment-webhook replays using owned fixtures. Put idempotency and constraints at the authoritative boundary. For AI endpoints, check caller authorization, input limits, request quotas, provider-spend limits, and failure behavior. Give agent tools only the scopes needed for the task and require the intended review step for external effects. Treat retrieved pages and uploaded files as untrusted data.

Validate uploads, recovery, and dependencies

Check content, size, storage permission, and safe serving behavior for uploads. Verify password-reset expiry, single use, and account-disclosure behavior for the actual design; a reel's fixed lifetime is not a universal OWASP rule. Examine production dependency advisories for reachable exposure and review fixes before applying them. Uploads (https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html) - Password resets (https://cheatsheetseries.owasp.org/cheatsheets/Forgot_Password_Cheat_Sheet.html)

```
npm audit --omit=dev
```

This inventory is one input to review, not a certificate that the application is safe. npm audit (https://docs.npmjs.com/cli/v11/commands/npm-audit/)

Verify failure and recovery

Exercise unavailable providers, timeouts, partial writes, retries, and exhausted quotas. Confirm that useful logs reach a monitored alert and that recovery instructions work. Test a backup restore on a disposable environment. Check keyboard access, form errors, loading states, mobile layout, and broken links so the intended user can complete the core task. Record material gaps before launch, assign owners, and retest fixes.

Reusable prompt

```
Build an application-specific launch review with synthetic accounts and owned fixtures. Cover cross-user access, privileged keys, data integrity, AI spending and tool scope, uploads, reset links, dependencies, partial failure, backup recovery, and core-task usability. Record expected behavior, observation, evidence, impact, fix, and retest; preserve unresolved gaps.
```

Project idea

Extend a launch workbook with an access matrix, negative tests, quota observations, and a restore drill. Select applicable ASVS requirements and keep the scope proportional to the application's data and external effects.

Original sources

- https://www.instagram.com/reel/DdKhqxHvjIP/
- https://www.instagram.com/reel/DcbDo37zTvJ/
- https://www.instagram.com/reel/DeM46Iay29L/
- https://www.instagram.com/reel/DfXVSPWBkDu/